2016 EXAMINATIONS

Lancaster University

Part II

COMPUTING AND COMMUNICATIONS [2 Hours]

SCC.363 Security and Risk

Candidates are asked to answer THREE questions from FOUR; each question is worth a total of 20 marks.

Use a separate answer book for each question.

Question 1

1.a Define a one-way function suitable for use in password generation, including its properties along with an example.

[**5 marks**]

1.b Explain the role of salt in password generation with an example.

[**5 marks**]

1.c The online banking system of a well known high street bank comes under an automated password cracking attack by a remote adversary who is using low-latency anonymous communication networks to carry out the attack. In the role of a government investigator, give a detailed description of a mechanism that can be used to trace the physical location of the attacker .

[**10 marks**]

Total 20 marks

Question 2

Security properties include confidentiality, integrity, availability, non-repudiation, untraceability, unobservability, unlinkability, and authenticity. In each of the following cases, describe which of these security properties are compromised, together with an explanation. In each case, briefly describe one countermeasure that might be employed to prevent the compromise.

2.a A DoS attack on a website

[**5 marks**]

2.b A keylogger that captures and sends sensitive data to the attacker

[**5 marks**]

2.c A phishing login page

[**5 marks**]

2.d A government backdoor installed in the outlook email program and the Skype VoIP client.

[**5 marks**]

Total 20 marks

Question 3

Ransomware is a type of malware that attacks by encrypting the victim's hard-drive and demands extortion money to reveal the encryption key. **Linux.Encoder.1** is a ransomware that affects linux-based computers.

3.a Key generation in Linux.Encoder.1 is carried out by generating a 256 bit random number used as the AES encryption key via calls to the *rand* function, which depends on the system time to key the random number generator. Once the key is generated it is immediately used to encrypt files on the victim's computer. Describe a defence technique that could be used to recover the encrypted files (without paying the attacker) in the given context.

[**10 marks**]

3.b Linux.Encoder.1 uses a webserver to accept payment that does not check or filter user input. Give a detailed example of a Cross Site Scripting (XSS) attack on the payment webserver.

[**10 marks**]

Total 20 marks

Question 4

4.a The WEP (Wired Equivalent Privacy) security protocol was designed for securing packets on wireless networks. It uses 24bits of Intialisation Vector (IV) to generate the keystream. Describe a fundamental vulnerability due to this design decision in the protocol. Propose an attack that can exploit this design vulnerability.

[**10 marks**]

4.b A face-recognition system installed at a busy airport is said to work with 99.99999% accuracy in recognising legitimate travellers. That is a one in a million chance of mistakenly recognising one person for another. How many people need to pass through an airport before the recognition system mistakenly detects one person as another. Describe and justify your argument in detail.

[**10 marks**]

Total 20 marks

---End of Paper---